



Security Code Review
del software per il voto referendario del
22/10/2017 sviluppato da Smartmatic
per Regione Lombardia

SINTESI DEI RISULTATI

06/10/2017

Disclaimer: The information contained in this document may change without notice, and may have been altered or changed if you have received it from a source other than Emaze S.p.A. All information provided in this document is provided "AS IS" with all faults without warranty of any kind, either expressed or implied. To the fullest extent permissible pursuant to applicable law, Emaze S.p.A. disclaims all warranties, expressed or implied, including the warranties of merchantability and fitness for a particular purpose. In no event shall Emaze S.p.A. be liable for any damages whatsoever, including direct, indirect, incidental, consequential, or special damages, arising from the use or dissemination hereof, even if Emaze S.p.A. authorized representative have been advised of the possibility of such damages. No part of this document shall be reproduced, republished, uploaded, posted, transmitted, or distributed by any means without written permission from Emaze S.p.A.

1 INTRODUZIONE

Con la firma del Decreto n 745 del 24/07/2017 il presidente della regione Lombardia ha indetto il referendum consultivo di domenica 22 ottobre 2017 per l'autonomia della Regione. Il Decreto, pubblicato nel Bollettino Ufficiale di Regione Lombardia n. 30 - Serie Ordinaria - del 27/07/2017, stabilisce anche l'utilizzo del voto elettronico in tutti i Comuni della Lombardia, che costituisce una novità nelle modalità di voto a livello nazionale.

La società Smartmatic è risultata l'aggiudicatrice del bando di gara indetto dalla Regione Lombardia, per quanto concerne la soluzione di voto elettronico.

La Regione Lombardia ha pertanto chiesto una valutazione – da effettuarsi da parte di una terza parte – della sicurezza del software sviluppato da Smartmatic e utilizzato per il voto elettronico.

Lombardia Informatica, attraverso i propri fornitori Ericsson, EY e Lutech che operano in RTI sulla Gara di Sicurezza nr. 606/2016 per la fornitura di servizi professionali in ambito Sicurezza delle Informazioni, ha selezionato la Emaze SpA, società italiana specializzata nell'ambito dell'Information Security con comprovata esperienza e competenze nell'ambito sia dello sviluppo software sicuro sia dell'analisi del codice sorgente e che opera sul mercato internazionale fornendo i propri servizi professionali alle maggiori aziende in ambito finanziario, telecomunicazioni e produttivo.

2 DESCRIZIONE DELLE ATTIVITÀ

2.1 Scopo dell'attività

Scopo dell'attività eseguita è stato quello di effettuare una code review applicativa del software realizzato da Smartmatic utilizzato all'interno dei dispositivi di voto elettronico. Oggetto dell'analisi è quindi il software utilizzato per la votazione.

Obiettivo dell'analisi è stato quello di verificare gli aspetti di sicurezza del software in uso e che gli stessi siano in grado garantire:

- anonimato del votante
- unicità del voto
- integrità dei dati elettorali
- correttezza del conteggio del risultato elettorale

pertanto l'analisi ha riguardato esclusivamente le parti di codice applicativo che fanno riferimento a tali funzionalità.

2.2 Overview della soluzione applicativa analizzata

La soluzione applicativa, scritta in C++03, consta di due componenti: un contesto di framework ed un contesto applicativo.

Quest'ultimo utilizza il framework per definire il workflow specifico per l'elezione. L'applicativo utilizza una struttura a plug-in per permettere il riutilizzo di componenti software, l'estensibilità e la customizzazione dell'applicazione elettorale.

La soluzione di Smartmatic consiste in un applicativo installato su un sistema Ubuntu 14.04 LTS, con kernel 4.12.0, con i moduli per l'accesso a internet e wifi disabilitati.

2.3 Modalità di esecuzione dell'attività

L'attività è stata svolta dal 19/09/2017 al 25/09/2017, in una sala dedicata della sede di Emaze S.p.A. in via Arrigo Protti 3, Trieste. Le attività sono state completate durante l'incontro del 27 settembre 2017 presso la sede di Regione Lombardia.

L'attività è iniziata con uno studio dell'architettura ad alto livello della soluzione Smartmatic e un'analisi del documento dei requisiti.

I seguenti documenti sono stati condivisi con Emaze per un supporto all'attività di code review.

Documento	Versione
Documento sui requisiti tecnico-funzionali della soluzione	3.0
High Level Architecture Document - Voting Application	2.0
Code style guides	4.0

Successivamente è iniziata l'operazione di analisi del codice sorgente, partendo dai diversi punti identificati in precedenza e seguendo il control flow delle operazioni elettorali. Particolare attenzione è stata posta nelle porzioni di codice relative al conteggio dei voti, sincronizzazione tra la memoria interna ed esterna, cifratura e firma dei file.

Per politica aziendale di SmartMatic, a tutela della proprietà intellettuale del software sviluppato, e pertanto non cedibile a terzi, l'attività di analisi del codice è stata eseguita mediante verifiche manuali effettuate analizzando il codice sorgente sul notebook di proprietà della stessa Smartmatic. Inoltre è stata svolta un'analisi statica del codice sorgente del framework e dell'applicativo utilizzando Clang Static Analyzer (in particolare l'eseguibile scan-build-3.9) installando lo stesso sul notebook di Smartmatic.

2.4 Modifiche apportate al codice analizzato

In data 25 settembre Smartmatic ha provveduto ad inviare al gruppo di lavoro Emaze alcuni file modificati con relativi hash: tali file sono stati analizzati e si è rilevato che i cambiamenti apportati non modificano i risultati delle analisi e le conclusioni riportate nel presente documento.

2.5 Compilazione del codice e calcolo del codice sicurezza della trusted build

In data 27 settembre 2017, presso la sede della Regione Lombardia alla presenza dei consulenti Smartmatic e dei referenti regionali, si è provveduto a verificare che i file da compilare siano gli stessi di cui si è effettuata l'analisi di sicurezza, inclusi quelli file inviati in data 25 settembre. Verificata questa corrispondenza, Smartmatic ha provveduto a compilare il codice sorgente e a installarlo sulla Voting Machine generando il codice di sicurezza di seguito riportato:

28 EC 98 D5 AC 9A 21 B2 95 FE E5 55 BB 0A BE A0 BC DE 84 26 CD 63 E5 48 A0
49 9D 5F 0C 87 3B E6

In fase di avvio della voting machine sarà necessario calcolare il codice di sicurezza utilizzando l'apposita funzionalità presente nell'applicativo. Se il codice mostrato a video dalla voting machine corrisponde con il codice

qui sopra riportato, si ha la certezza che il software installato non è stato in alcun modo manomesso o modificato rispetto a quello qui analizzato e di cui è stata verificata la sicurezza del codice sorgente.

3 SINTESI DEI RISULTATI

L'attività di Code Review eseguita non ha evidenziato problematiche di sicurezza dirette e la **soluzione sviluppata da Smartmatic ha un livello di sicurezza adeguato rispetto al contesto d'utilizzo** nell'ambito del voto elettronico.

A seguito dell'attività e delle analisi effettuate si conferma pertanto che i seguenti aspetti della soluzione di voto elettronico sono garantiti

- Anonimato del votante;
- Unicità del voto;
- Integrità dei dati elettorali
- Correttezza del conteggio del risultato elettorale.